

Cover

Week 2, Days 4 and 5 Lab: Hardening Windows Servers

By: Jason Man

August 14, 2026



Part 1: Local Security Policy

Day 4, Part 1: Local Security Policy

1. Open Local Security Policy and review the current password policy (minimum length, complexity, maximum age).
2. Set a minimum password length of at least 12 characters with complexity requirements enabled.

Policy	Security Setting
Enforce password history	0 passwords remembered
Maximum password age	42 days
Minimum password age	0 days
Minimum password length	12 characters
Minimum password length audit	Not Defined
Password must meet complexity requirements	Enabled
Relax minimum password length limits	Not Defined
Store passwords using reversible encryption	Disabled

3. Configure account lockout policy: lock the account after 5 invalid attempts, with a minimum 15-minute

Policy	Security Setting
Account lockout duration	15 minutes
Account lockout threshold	5 invalid logon attempts
Allow Administrator account lockout	Enabled
Reset account lockout counter after	15 minutes

lockout duration.

4. Enable auditing for logon events (both success and failure) under Local Policies > Audit Policy

Audit logon events Properties



Local Security Setting

Explain



Audit logon events

Audit these attempts:

☒ Success

☒ Failure

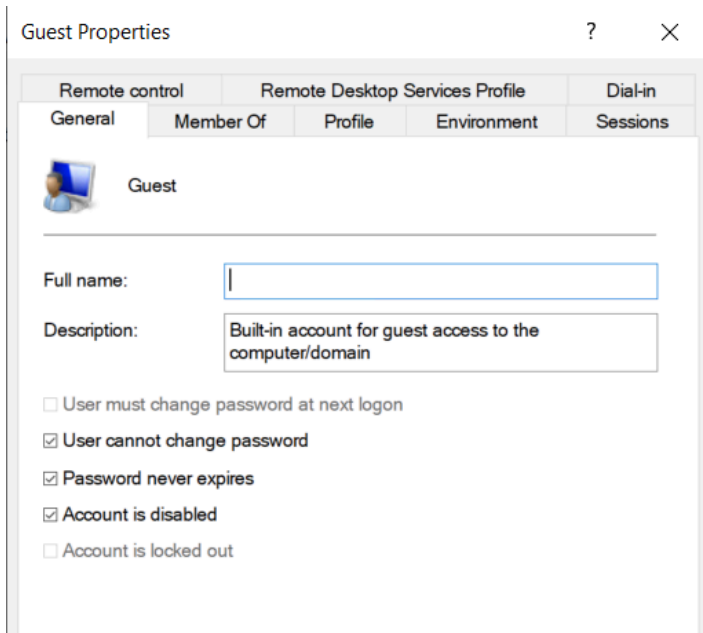


This setting might not be enforced if other policy is configured to override category level audit policy.
For more information, see [Audit logon events](#). (Q921468)

Part 2: User, Group, and Service Hardening

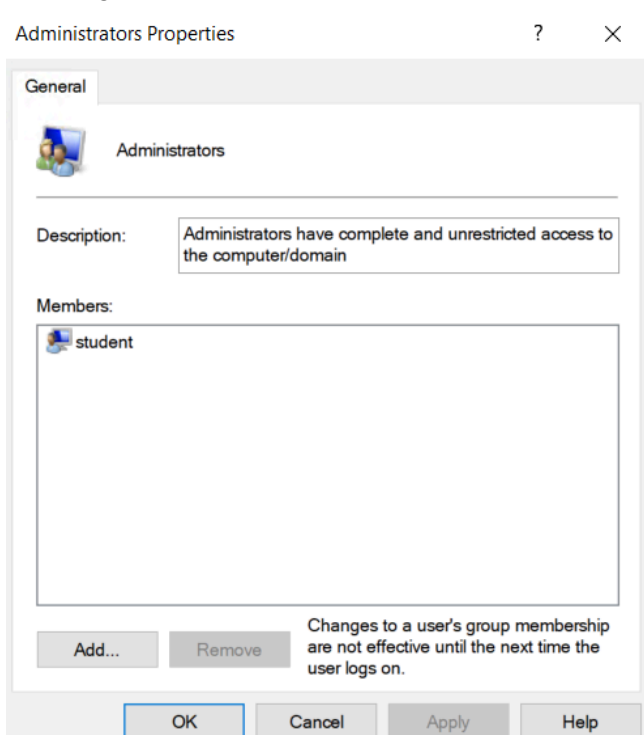
Day 4, Part 2: User, Group, and Service Hardening

1. Review local users (lusrmgr.msc): disable the built-in Guest account if enabled, and rename the built-in



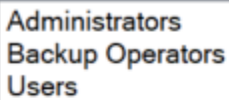
Administrator account.

2. Review local group membership, especially Administrators, and remove any account that doesn't need standing admin access.



Students require admin access to complete the lab. There are no changes to be made.

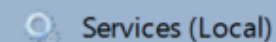
3. Review User Rights Assignment for "Log on locally" and "Access this computer from the network," and restrict them to only the accounts/groups that need them.



Administrators
Backup Operators
Users

Administrators and backup operators need access. Standard users do not, as it is a Windows Server environment.

4. Review running services (services.msc), identify at least two that aren't needed for this host's role, and disable them.

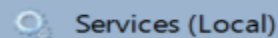


Services (Local)

Print Spooler

[Stop](#) the service
[Restart](#) the service

Description:
This service spools print jobs and handles interaction with the printer. If you turn off this service, you won't be able to print or see your printers.



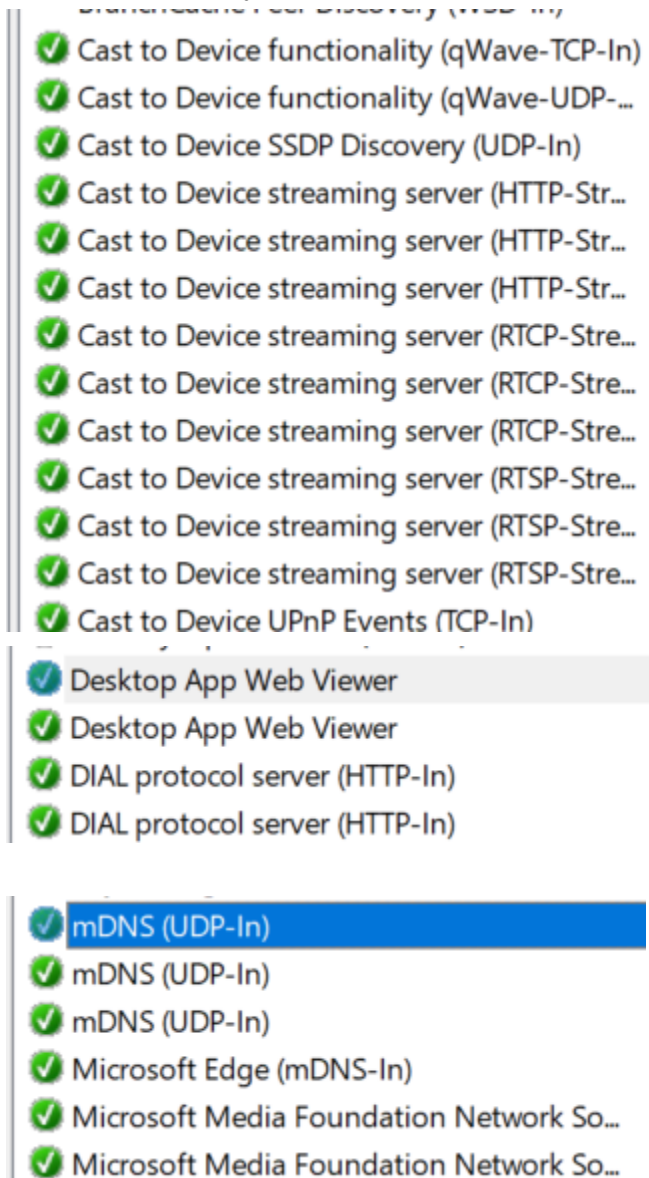
Services (Local)

Special Administration Console Helper

[Stop](#) the service
[Pause](#) the service
[Restart](#) the service

Description:
Allows administrators to remotely access a command prompt using Emergency Management Services.

5. Review Windows Firewall with Advanced Security inbound rules, and disable or remove any rule that allows unnecessary inbound access



Core Networking — IPHTTPS (TCP-In)

- relevant to Ipv6 networking

Teredo (UDP-In) - unnecessary on hardened server

Delivery Optimization (TCP-In) - P2P is a risk

Delivery Optimization (UDP-In) - same reason

Disabling mDNS - Not needed in a hardened environment.

Part 3: BitLocker Drive Encryption

Day 5, Part 3: BitLocker Drive Encryption

1. Confirm TPM availability on the host (tpm.msc or Get-Tpm in PowerShell).

```
PS C:\Users\student> Get-Tpm
>>

TpmPresent           : True
TpmReady             : True
TpmEnabled           : True
TpmActivated         : True
TpmOwned             : False
RestartPending       : False
ManufacturerId       : 1297303124
ManufacturerIdTxt     : MSFT
ManufacturerVersion   : 8224.786.18.4
ManufacturerVersionFull20 : 8224.786.18.4

ManagedAuthLevel     : Full
OwnerAuth             :
OwnerClearDisabled    : False
AutoProvisioning      : Enabled
LockedOut             : False
LockoutHealTime       : 16 minutes 40 seconds
LockoutCount          : 0
LockoutMax            : 3
SelfTest              : {}
```

- TpmPresent and TpmReady both showing True

2. Enable BitLocker on the data volume containing sensitive file shares, choosing an appropriate authentication method (TPM, or TPM + PIN).

Fixed data drives

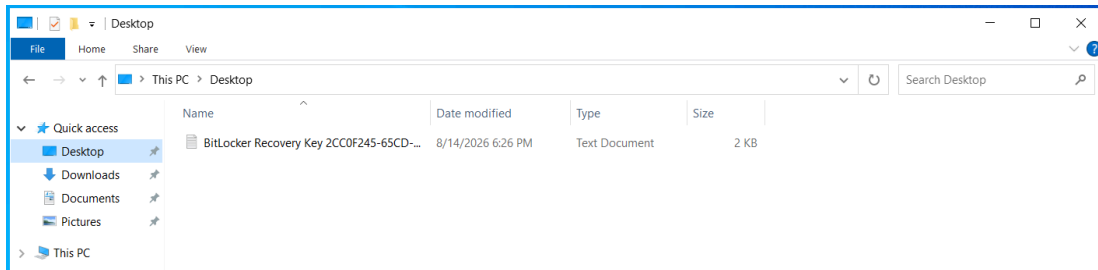
Temporary Storage (D:) BitLocker Encrypting



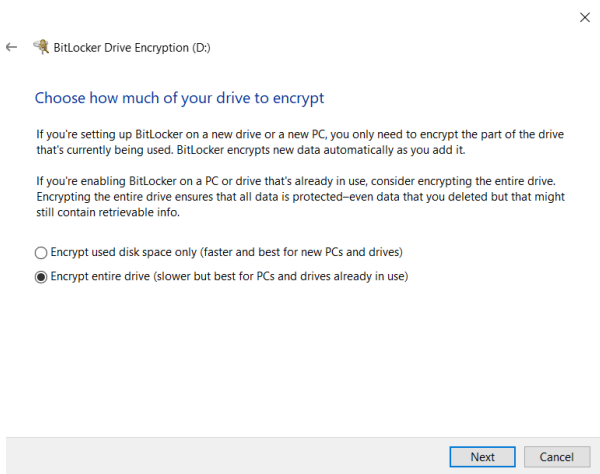
-  Back up your recovery key
- [Change password](#)
-  Remove password
-  Add smart card
-  Turn on auto-unlock
-  Turn off BitLocker

- *Note: Windows only gives the "TPM" option when encrypting the main OS drive (C:) first. As to avoid breaking the VM, we encrypted the (D:) drive with "Password" for the authentication method

3. When prompted, save the BitLocker recovery key to a secure location provided by your instructor — never leave it on the encrypted drive itself.



- For lab purposes, the recovery key is saved to Desktop



- Fully encrypt the entire drive

4. Monitor encryption progress and confirm it completes: manage-bde -status

```
PS C:\Users\student> manage-bde -status
BitLocker Drive Encryption: Configuration Tool version 10.0.20348
Copyright (C) 2013 Microsoft Corporation. All rights reserved.

Disk volumes that can be protected with
BitLocker Drive Encryption:
Volume C: [Windows]
[OS Volume]

    Size:                126.45 GB
    BitLocker Version:    None
    Conversion Status:    Fully Decrypted
    Percentage Encrypted: 0.0%
    Encryption Method:    None
    Protection Status:    Protection Off
    Lock Status:          Unlocked
    Identification Field: None
    Key Protectors:       None Found

Volume D: [Temporary Storage]
[Data Volume]

    Size:                32.00 GB
    BitLocker Version:    2.0
    Conversion Status:    Fully Encrypted
    Percentage Encrypted: 100.0%
    Encryption Method:    XTS-AES 128
    Protection Status:    Protection On
    Lock Status:          Unlocked
    Identification Field: Unknown
    Automatic Unlock:     Disabled
    Key Protectors:
        Password
        Numerical Password

PS C:\Users\student>
```

- Data Volume Drive seen fully encrypted

Part 4: Verification Script

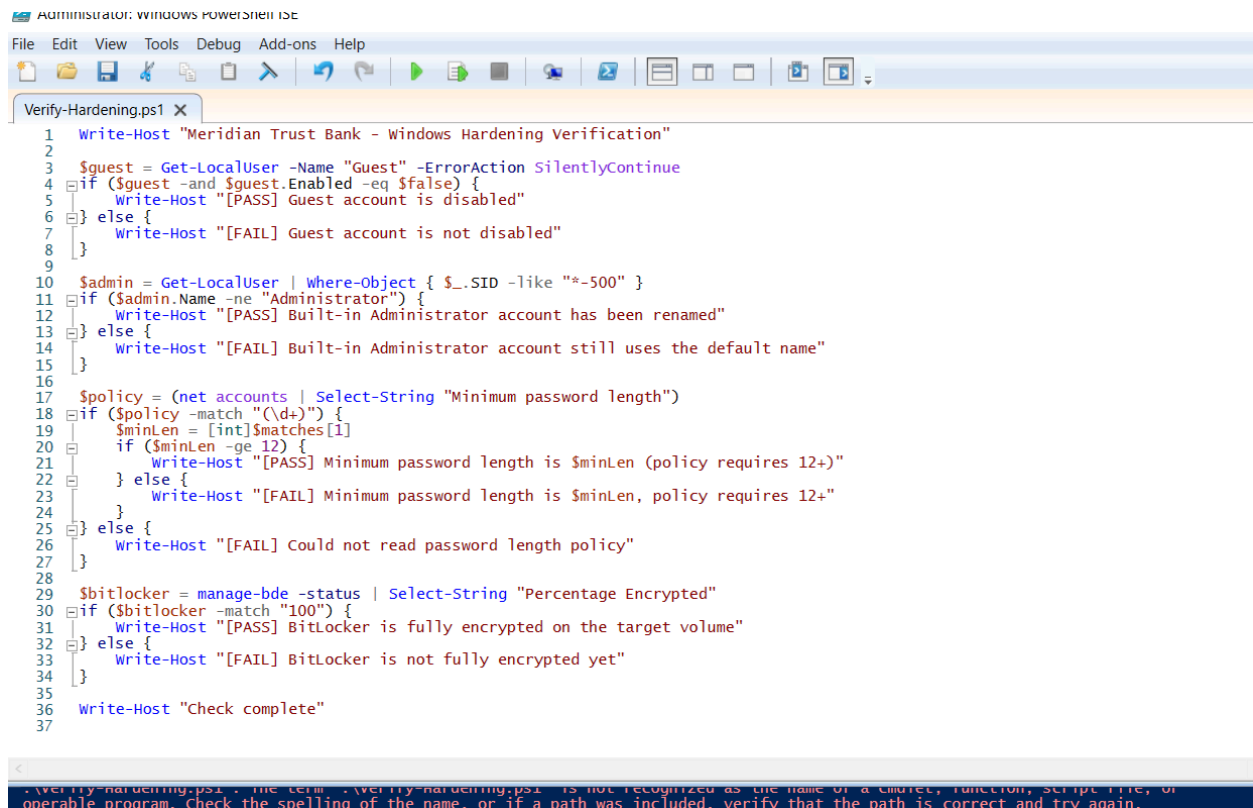
Day 5, Part 4: Verification Script

Write a PowerShell script (Verify-Hardening.ps1) that checks the host against today's changes and reports

PASS/FAIL for each. At minimum, it should check:

- That the Guest account is disabled
- That the built-in Administrator account has been renamed
- That the configured password minimum length meets policy
- That BitLocker is enabled and fully encrypted on the target volume

1. Run your script and capture its output as evidence.
2. Fix anything your own script flags as a FAIL before submitting



```
Administrator: Windows PowerShell ISE
File Edit View Tools Debug Add-ons Help
Verify-Hardening.ps1 X
1 Write-Host "Meridian Trust Bank - Windows Hardening Verification"
2
3 $guest = Get-LocalUser -Name "Guest" -ErrorAction SilentlyContinue
4 if ($guest -and $guest.Enabled -eq $false) {
5     Write-Host "[PASS] Guest account is disabled"
6 } else {
7     Write-Host "[FAIL] Guest account is not disabled"
8 }
9
10 $admin = Get-LocalUser | Where-Object { $_.SID -like "*-500" }
11 if ($admin.Name -ne "Administrator") {
12     Write-Host "[PASS] Built-in Administrator account has been renamed"
13 } else {
14     Write-Host "[FAIL] Built-in Administrator account still uses the default name"
15 }
16
17 $policy = (net accounts | Select-String "Minimum password length")
18 if ($policy -match "(\\d+)") {
19     $minLen = [int]$matches[1]
20     if ($minLen -ge 12) {
21         Write-Host "[PASS] Minimum password length is $minLen (policy requires 12+)"
22     } else {
23         Write-Host "[FAIL] Minimum password length is $minLen, policy requires 12+"
24     }
25 } else {
26     Write-Host "[FAIL] Could not read password length policy"
27 }
28
29 $bitlocker = manage-bde -status | Select-String "Percentage Encrypted"
30 if ($bitlocker -match "100") {
31     Write-Host "[PASS] BitLocker is fully encrypted on the target volume"
32 } else {
33     Write-Host "[FAIL] BitLocker is not fully encrypted yet"
34 }
35
36 Write-Host "Check complete"
37

.\verify-hardening.ps1 : The term '.\verify-hardening.ps1' is not recognized as the name of a cmdlet, function, script file, or
operable program. Check the spelling of the name, or if a path was included, verify that the path is correct and try again.
```

- In Powershell ISE, the verification script file "Verify-Hardening.ps1" is created

```
PS C:\Users\student> cd Documents

PS C:\Users\student\Documents> .\Verify-Hardening.ps1
Meridian Trust Bank - Windows Hardening Verification
[PASS] Guest account is disabled
[PASS] Built-in Administrator account has been renamed
[PASS] Minimum password length is 12 (policy requires 12+)
[PASS] BitLocker is fully encrypted on the target volume
Check complete
```

- Executed script returns PASS for all areas tested

Hardening Summary and Reflection

Hardening Summary

Tie your work across both days back to these mitigation strategies from the lecture:

- Enforcing group policies to secure user accounts and system settings
- Using encryption tools like BitLocker to protect sensitive data

Write a short hardening summary (5–10 sentences) covering what you changed in local policy, what accounts/services you locked down, and how you verified encryption — written as handoff note to the infrastructure team

To start, we first looked at the Local Security Policy settings. We found a few options that could be tweaked. We set the minimum password length to 12 characters, changed the login failure attempts to five, enforced a 15 minute timer after those failed attempts, and enabled auditing for both logon successes and failures. Next, we took a look at Users, groups, and services. We reviewed any accounts that may have had admin permissions (none did). We disabled standard users from logging into the environment, as they do not need access to the server. Service wise, we disabled the Print Spooler and Special Administration Console Helper. Firewall rule wise, we disabled the Cast-to-device entries, as well as the Desktop Viewer and DIAL rules. Next, we utilized BitLocker to fully encrypt our data drive (D:) to secure files at rest. Finally, we verified we met the policies of the Guest account being disabled, the built-in Administrator account being renamed, the configured password minimum length meets policy, and that the BitLocker is enabled and fully encrypted on the target volume.

Reflection Questions

Answer briefly in your own words (3–5 sentences each):

1. Why is renaming the built-in Administrator account and disabling Guest considered a baseline step rather than optional hardening?

Renaming the built-in administrator account and disabling the Guest account is a baseline step because Guest accounts can often have no password or a very basic password. Disabling it prevents attacks on it. The administrator account should be renamed because an attacker would not be able to guess the account name of the admin if changed.

2. What's the practical difference in risk between an unencrypted drive that's access-controlled and an encrypted drive like the one you set up today? When does BitLocker actually matter?

The practical difference between an unencrypted drive that's access controlled is that access controls only protect data when the OS is actively running and enforcing permissions. BitLocker is important in situations where there is physical compromise or stolen hardware, as it encrypts data at rest.

3. If you lost the BitLocker recovery key in a real production environment, what would that mean for the bank — and how does that change how you'd store it

If you lost the BitLocker Recovery Key, you would most likely face scrutiny at work (Maybe even fired). Without the key, the device's contents are not recoverable/decryptable. The possibility of this happening requires you to store the key safely in something like a key escrow.